



Zodiac Signature Patch Audit

Gnosis Ltd - Report by Côme du Crest

2026-06-12



Table of contents

- Table of contents
- Zodiac Signature Patch Audit
 - Scope
 - Context
 - Status
 - Legal Information And Disclaimer

Zodiac Signature Patch Audit

This document presents the findings of a smart contract audit conducted by Côme du Crest for Gnosis Ltd.

Scope

The scope includes the patched v1.1.1 Delay modifier at address [0x824175b945838d127c1ca83cbce11d8e44f6df01](#) on Gnosis Chain as well as the patched v2.1.1 Roles modifier at address [0xf2964ce6161ce0e75964fe7927ce114cb0b283d5](#) on Gnosis Chain.

This audit only verifies that the newly deployed patched contracts fix the vulnerability identified in the [SignatureChecker](#) contract and relies on previous audits for the global security assessment of the remaining parts of the contracts.

Context

The signature checker of deployed v1.1.0 Delay at address [0x01F8cabB808D7dE0dF4202D4B60C8310d2f1339b](#) and v2.1.0 Roles modifier at address [0x9646fdad06d3e24444381f44362a3b0eb343d337](#) on Gnosis Chain contains the following vulnerability:

```
1  abstract contract SignatureChecker {
2      ...
3      function _isValidContractSignature(
4          address signer,
5          bytes32 hash,
6          bytes calldata signature
7      ) internal view returns (bool result) {
8          uint256 size;
9          // eslint-disable-line no-inline-assembly
10         assembly {
11             size := extcodesize(signer)
12         }
13         if (size == 0) {
14             return false;
15         }
16
17         (, bytes memory returnData) = signer.staticcall(
18             abi.encodeWithSelector(
19                 IERC1271.isValidSignature.selector,
20                 hash,
21                 signature
22             )
23         );
24
25         return bytes4(returnData) == EIP1271_MAGIC_VALUE;
26     }
```

```
27     ...
28 }
```

The return value of the EIP1271 `staticcall` is not checked. As a result if the called `signer` reverts with the EIP1271 magic value then the signature checker will accept the signature as valid.

This can be exploited if the `signer` calls external contracts that may maliciously revert with the EIP1271 magic value to make the error bubble up to `SignatureChecker` to circumvent a proper signature verification.

The patched contracts check the `success` value of the `staticcall()` which blocks the explained attack vector:

```
1  abstract contract SignatureChecker {
2      function _isValidContractSignature(
3          address signer,
4          bytes32 hash,
5          bytes calldata signature
6      ) internal view returns (bool result) {
7          uint256 size;
8          // eslint-disable-line no-inline-assembly
9          assembly {
10             size := extcodesize(signer)
11         }
12         if (size == 0) {
13             return false;
14         }
15
16         (bool success, bytes memory returnData) = signer.staticcall(
17             abi.encodeWithSelector(
18                 IERC1271.isValidSignature.selector,
19                 hash,
20                 signature
21             )
22         );
23
24         return success && bytes4(returnData) == EIP1271_MAGIC_VALUE;
25     }
26 }
```

Status

The identified issue during the attack has been patched in the inspected contracts.

The report has been sent to the core developer.

Legal Information And Disclaimer

1. This report is based solely on the information provided by Zodiac, with the assumption that the information provided is authentic, accurate, complete, and not misleading as of the date of this report. Gnosis has not conducted any independent enquiries, investigations or due diligence in respect of the Company, its business or its operations.
2. Changes to the information contained in the documents, repositories and any other materials referenced in this report might affect or change the analysis and conclusions presented. Gnosis is not responsible for monitoring, nor will we be aware of, any future additions, modifications, or deletions to the audited code. As such, Gnosis does not assume any responsibility to update any information, content or data contained in this report following the date of its publication.
3. This report does not address, nor should it be interpreted as addressing, any regulatory, tax or legal matters, including but not limited to: tax treatment, tax consequences, levies, duties, data privacy, data protection laws, issues relating to the licensing of information technology, intellectual property, money laundering and countering the financing of terrorism, or any other legal restrictions or prohibitions. Gnosis disclaims any liability for omissions or errors in the findings or conclusions presented in this report.
4. The views expressed in this report are solely our views regarding the specific issues discussed within this report. This report is not intended to be exhaustive, nor should it be construed as an assurance, guarantee or warranty that the code is free from bugs, vulnerabilities, defects or deficiencies. Different use cases may carry different risks, and integration with third-party applications may introduce additional risks.
5. This report is provided for informational purposes only and should not be used as the basis for making investment or financial decisions. This report does not constitute investment research and should not be viewed as an invitation, recommendation, solicitation or offer to subscribe for or purchase any securities, investments, products or services. Gnosis is not a financial advisor, and this report does not constitute financial or investment advice.
6. The statements in this report should be considered as a whole, and no individual statement should be extracted or referenced independently.
7. This report is addressed exclusively to Zodiac, and except with prior written consent from Gnosis, it may not be shared, disclosed, transmitted, or relied upon by any other person or entity for any purpose.
8. To the fullest extent permitted by applicable laws, Gnosis disclaims any and all other liability, whether in contract, tort, or otherwise, that may arise from this report or the use thereof.